

Prepared For: Food Remedy API Team

Author: Riken patel

Date: 11/05/2026

Table of Contents

Research Summary	1
Common Security Practices in Mobile Health Applications.....	2
1. Secure Authentication	2
2. Encrypted API Communication	2
3. Secure Data Storage.....	2
4. Strong API Access Control	2
5. Privacy Compliance	3
Sensitive Data in Food Remedy API	3
Common Vulnerabilities	3
Comparison of Large-Scale Platform Approaches	5
Recommended Strategies for Food Remedy API.....	5
Conclusion.....	5

Research Summary

Mobile health and nutrition applications handle sensitive user information such as personal profiles, dietary preferences, allergy details, health goals, food history, and recommendation data. Because this information can affect user privacy and trust, applications must use strong security practices after deployment. For Food Remedy API, security is important because the system may store user nutrition profiles, product preferences, demographic information, and personalized food recommendations.

Modern mobile health applications commonly protect users through secure authentication, encrypted communication, encrypted storage, strict API access control, privacy policies, and regular monitoring. OWASP identifies common mobile risks such as insecure authentication, insecure communication, inadequate privacy controls, insecure data storage, and weak cryptography. These risks are directly relevant to mobile food and health apps.

Common Security Practices in Mobile Health Applications

A secure mobile health application should include:

1. Secure Authentication

Users should log in using secure methods such as email/password authentication, OAuth, Firebase Authentication, or multi-factor authentication. Passwords should never be stored in plain text. Access tokens should be stored securely and expire after a set time.

2. Encrypted API Communication

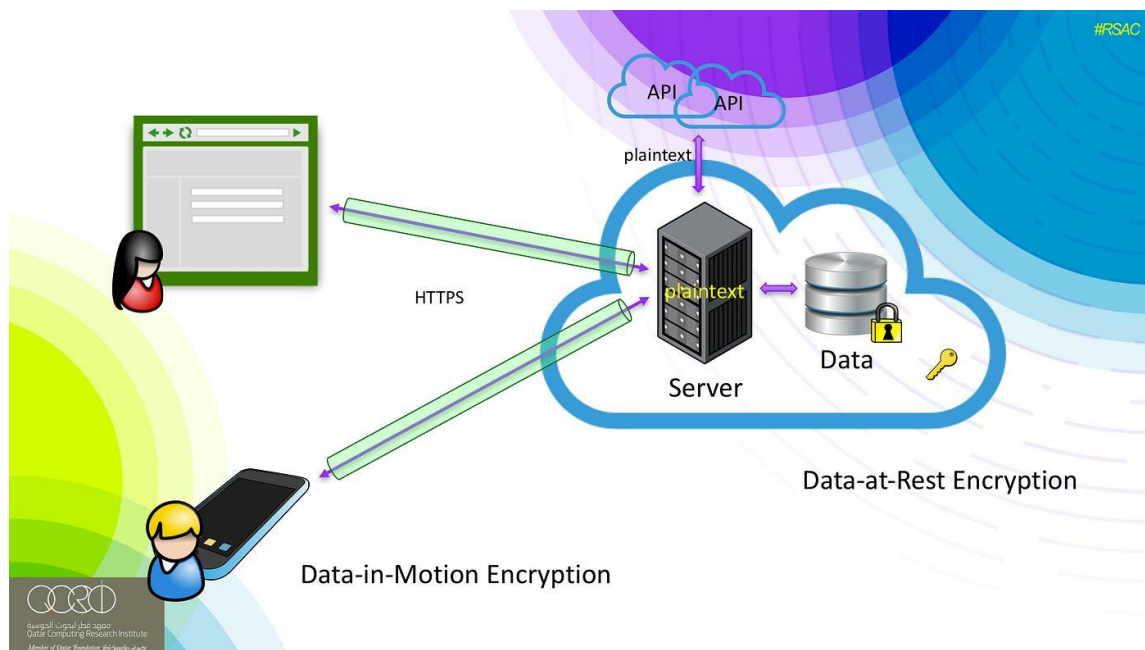
All communication between the mobile app and backend API should use HTTPS/TLS. This protects sensitive data from being intercepted while travelling between the user's device and the server.

3. Secure Data Storage

Sensitive user data should not be stored in plain text on the mobile device. Tokens, health data, and personal profile details should be stored using secure storage options such as encrypted local storage or platform-provided secure storage.

4. Strong API Access Control

The backend should check whether the logged-in user is allowed to access or update each record. OWASP API guidance highlights broken object-level and property-level authorization as major API risks, meaning APIs must prevent users from accessing other users' private data.



5. Privacy Compliance

In Australia, health information is treated as sensitive information, and privacy law applies strict rules to how organizations collect, use, and disclose it. Food Remedy should follow Australian Privacy Principles by collecting only necessary data, explaining why data is collected, and protecting it from misuse.

Sensitive Data in Food Remedy API

Food Remedy may handle the following sensitive data:

Data Type	Privacy Risk	Protection Method
User profile details	Personal identification risk	Store securely and limit access
Dietary preferences	Reveals lifestyle/health habits	Encrypt and use only for recommendations
Allergy information	Health-related sensitive data	Strong access control
Product search history	Behavior tracking risk	Minimize unnecessary storage
Demographic data	Personalization and profiling risk	Use consent and privacy controls
Recommendation results	May reveal health goals	Protect through secure API responses

Common Vulnerabilities

Common mobile and API vulnerabilities include insecure token storage, weak authentication, exposing too much user data in API responses, missing input validation, insecure cloud storage, and poor privacy controls. OWASP Mobile Top 10 includes risks such as insecure communication, inadequate privacy controls, insecure data storage, and insufficient cryptography.



Figure 2: Common security vulnerabilities affecting mobile and API-based health applications according to OWASP mobile security risks.

For Food Remedy, examples of possible risks include:

- A user accessing another user's profile by changing an ID in the API request.
- Dietary or allergy data being stored without encryption.
- API responses returning unnecessary personal information.
- Authentication tokens being stored insecurely.
- Debug logs exposing private user data.
- Missing rate limits allowing automated abuse.

Comparison of Large-Scale Platform Approaches

Large-scale health and nutrition platforms usually apply layered security. They use secure login systems, HTTPS-only communication, encrypted databases, cloud access control, monitoring, consent-based data collection, and privacy policies. The main pattern is defence -in-depth, meaning no single security control is trusted by itself. Authentication, authorization, encryption, monitoring, and privacy governance work together.

Food Remedy can follow the same approach by combining secure login, Firebase/cloud security rules, encrypted API traffic, backend validation, and clear privacy handling.

Recommended Strategies for Food Remedy API

Food Remedy should apply the following strategies:

1. Use HTTPS for all API communication.
2. Store authentication tokens securely, not in plain text.
3. Validate user permissions on every API request.
4. Return only the data needed by the frontend.
5. Encrypt sensitive user data in storage.
6. Avoid logging health, allergy, or profile information.
7. Use secure cloud storage and database access rules.
8. Add input validation to prevent invalid or harmful data.
9. Apply rate limiting to protect APIs from abuse.
10. Provide clear privacy information and consent options.
11. Regularly test the app against OWASP Mobile and API risks.
12. Keep dependencies updated to reduce supply chain security risks.

Conclusion

Security and privacy are essential for mobile health and nutrition applications because users share sensitive personal and health-related information. For Food Remedy API, strong authentication, encrypted communication, secure storage, strict API authorization, and privacy-compliant data handling will help protect user trust. By following OWASP mobile and API security practices and applying Australian privacy principles, Food Remedy can create a safer, more reliable, and scalable application environment.